Laboratorio: Políticas de contraseña seguras en Windows

Objetivo

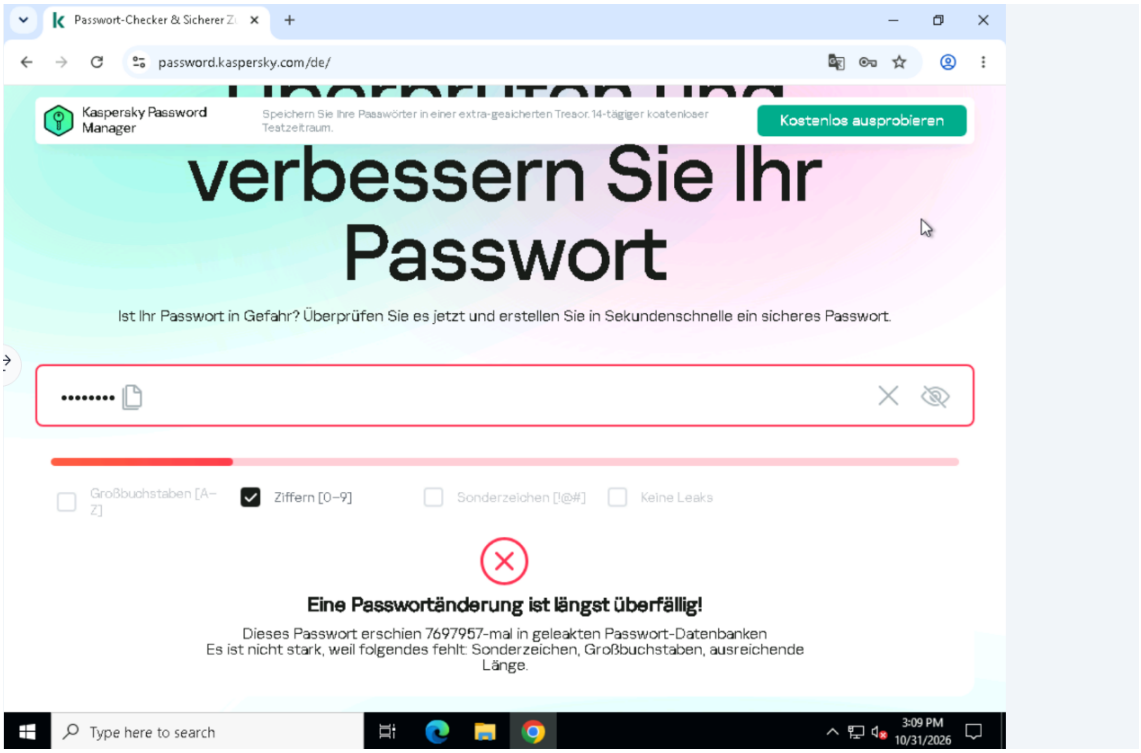
Aprender a configurar y verificar políticas de contraseña seguras en Windows usando el Editor de directivas de grupo local, y comprender por qué son un control preventivo clave en la seguridad de un sistema operativo.

Herramientas y entorno

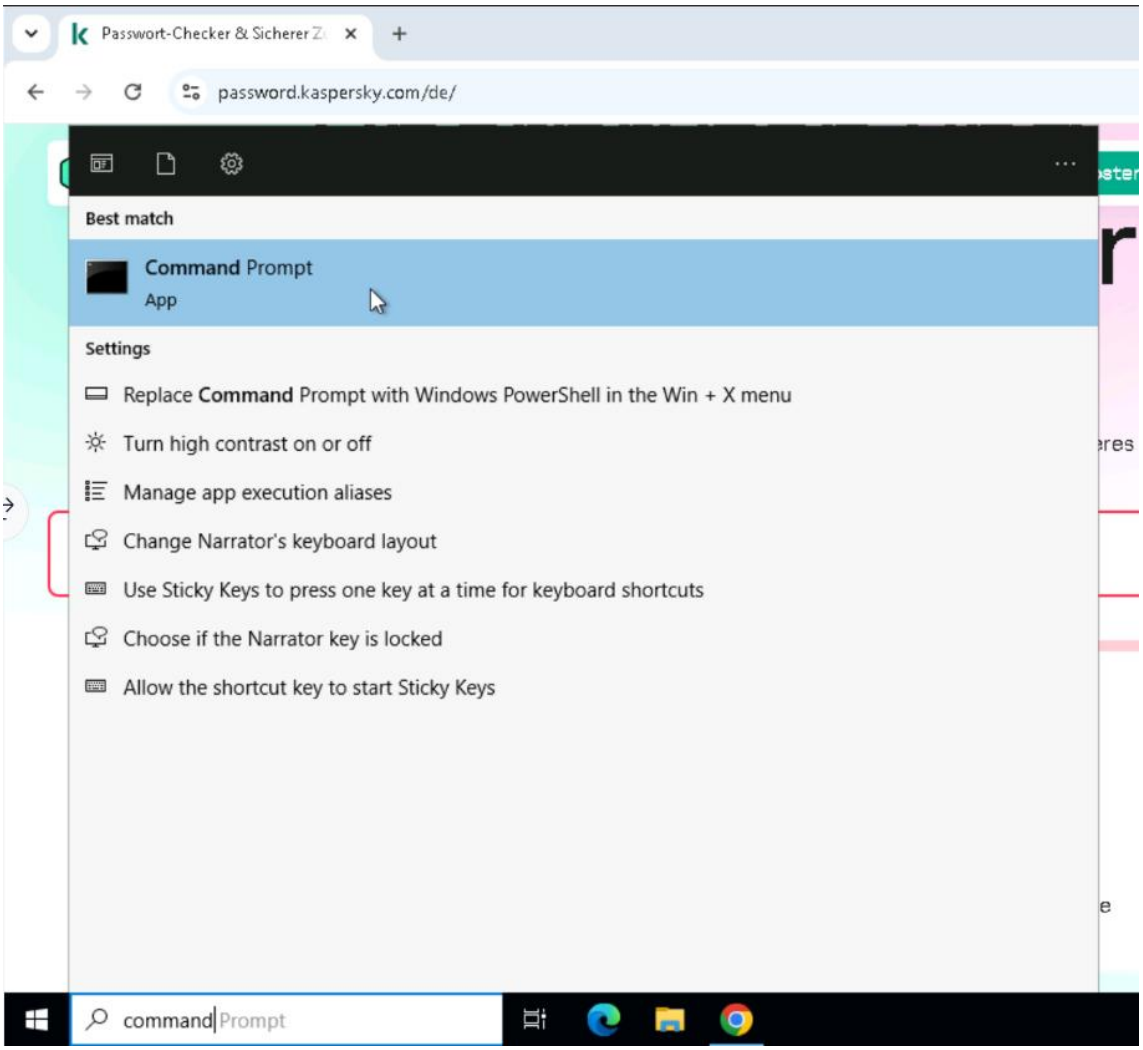
- Sistema operativo: Windows (máquina local / laboratorio)
- Editor de directivas de grupo local (gpedit)
- Kaspersky Password Checker (para evaluar la fortaleza de contraseñas)

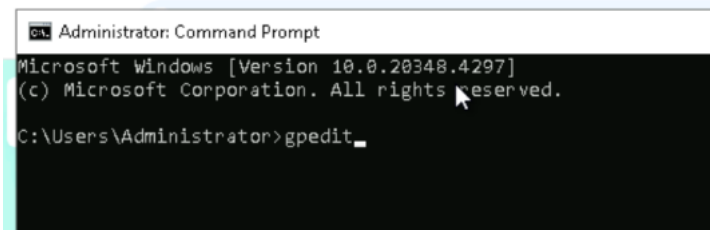
Pasos realizados

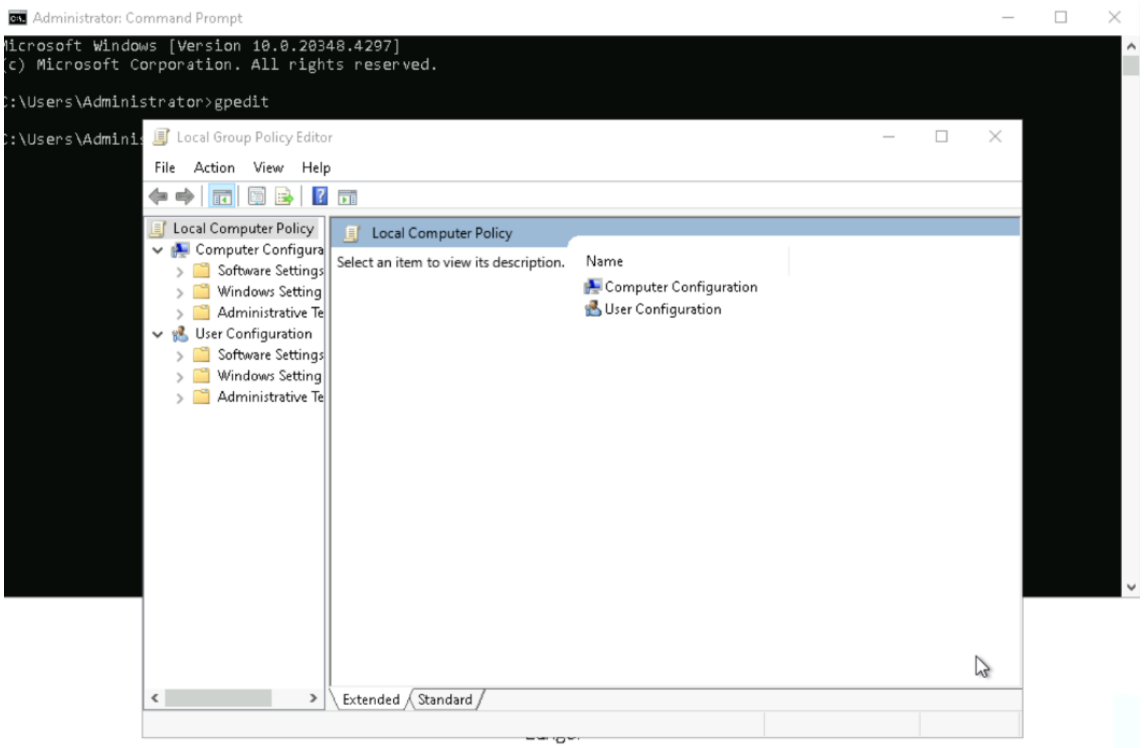
Paso 1: Evaluar la fortaleza de contraseñas con Kaspersky Entré a Kaspersky Password Checker y probé contraseñas de distinta longitud y variedad de caracteres, viendo cómo afectan el tiempo de descifrado.

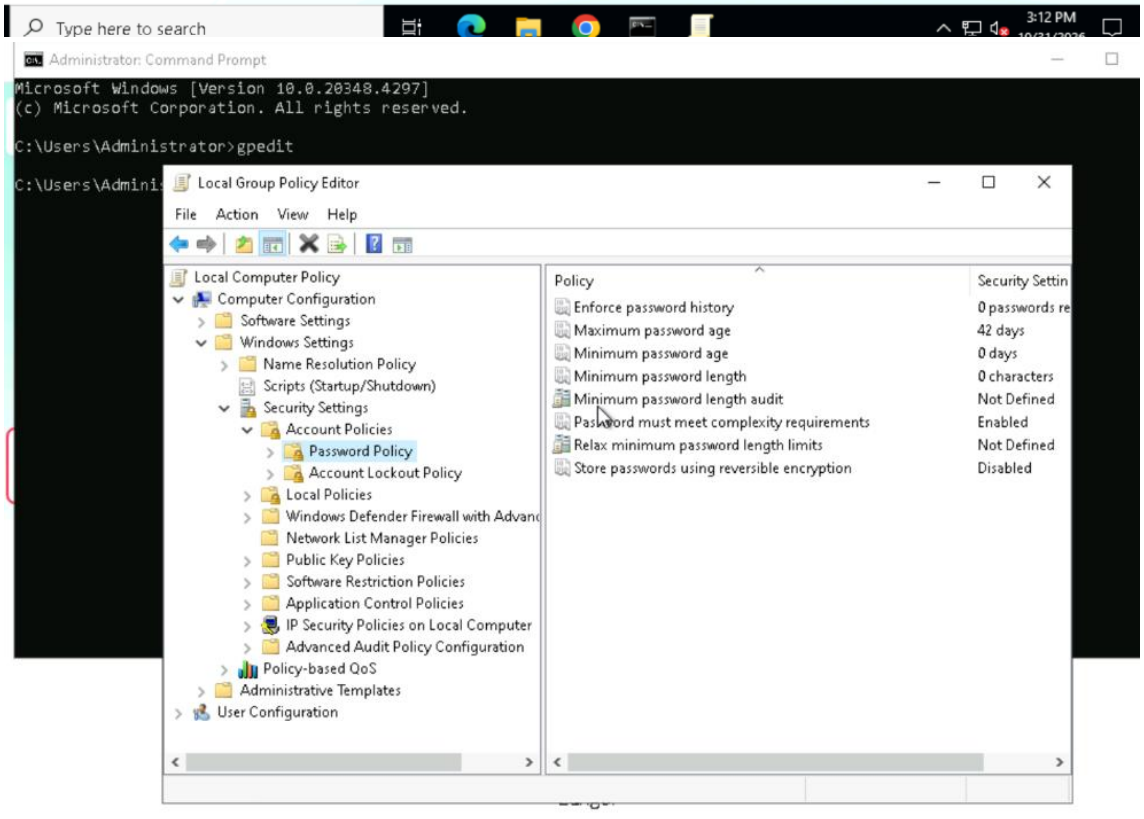


Paso 2: Abrir el Editor de directivas de grupo local Abrí el símbolo del sistema y ejecuté `gpedit` para abrir el Editor de directivas de grupo local.

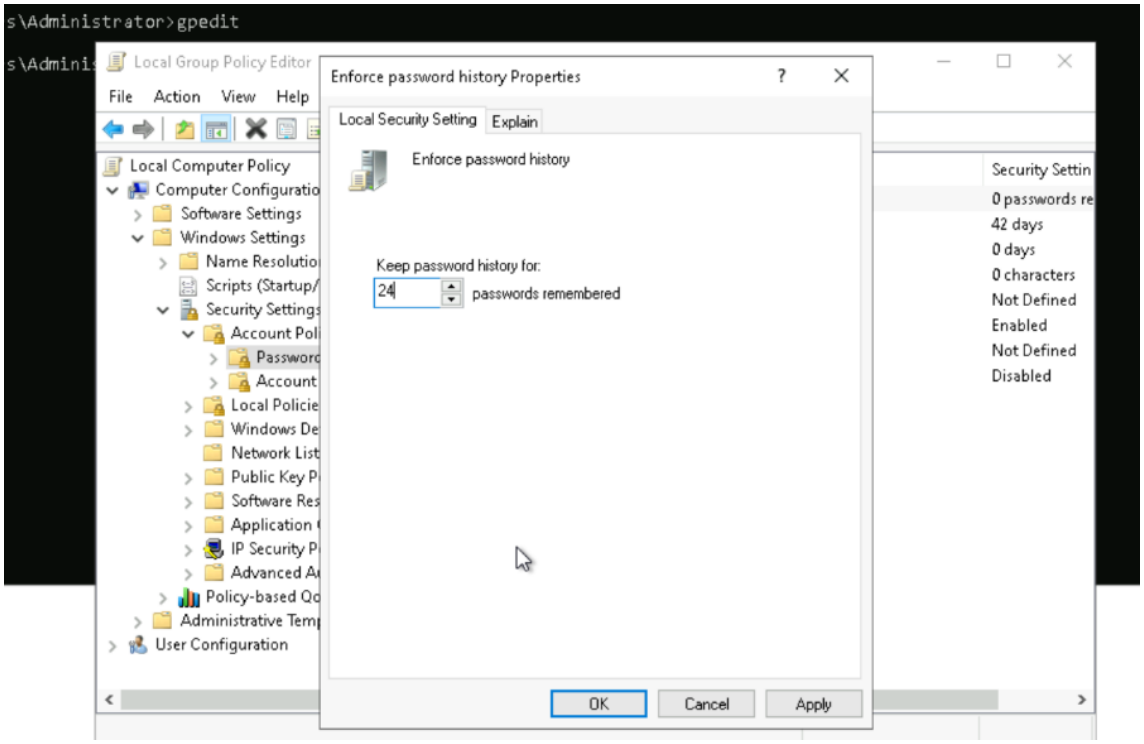




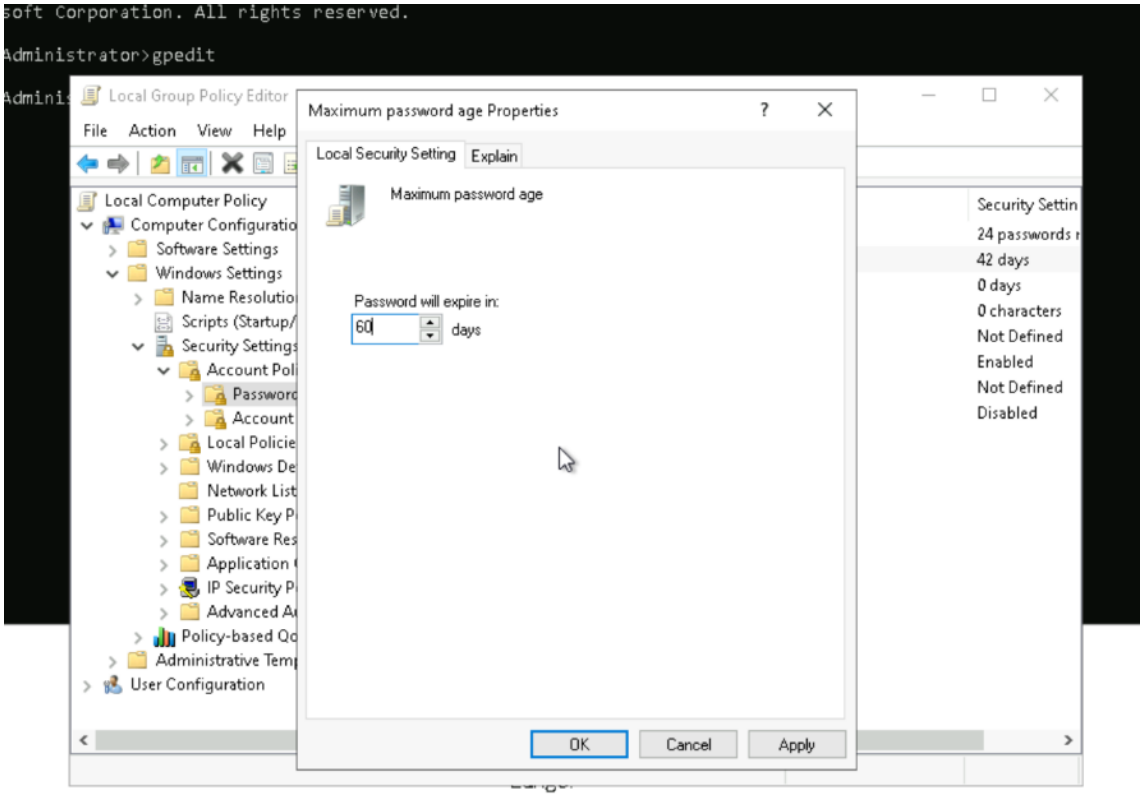




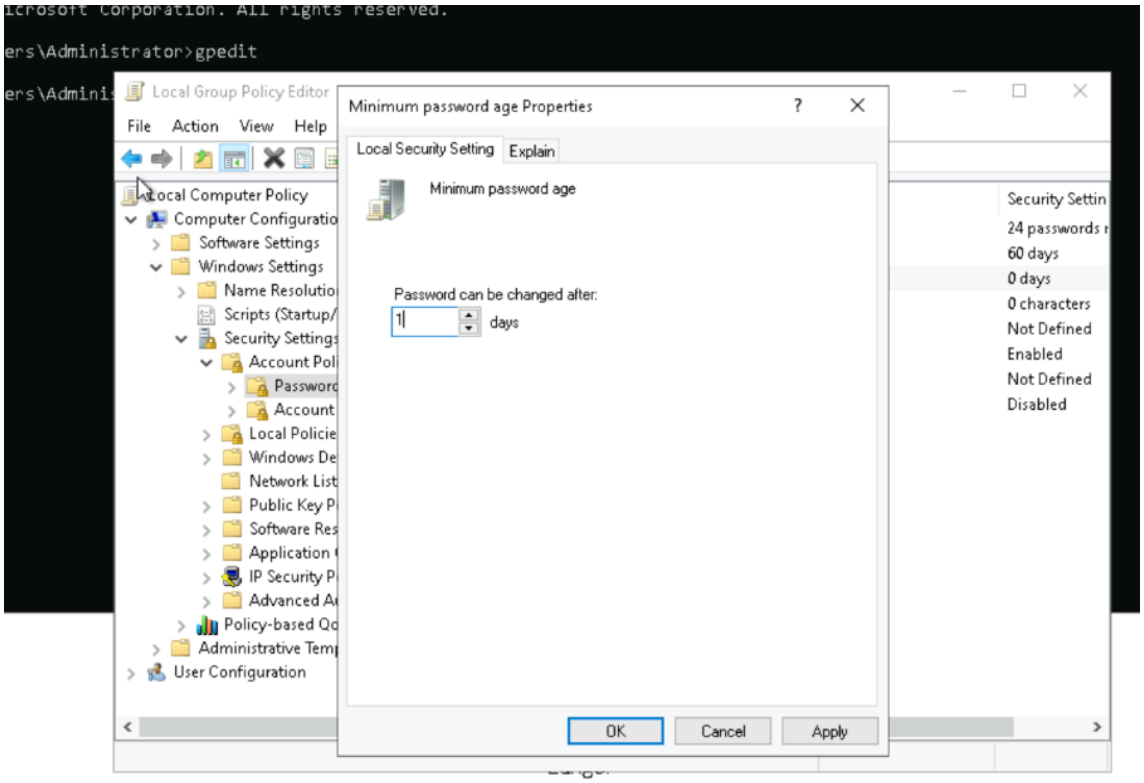
Paso 3: Configurar "Exigir historial de contraseñas" Configuré el historial en 24, para que el usuario no pueda reutilizar las últimas 24 contraseñas.



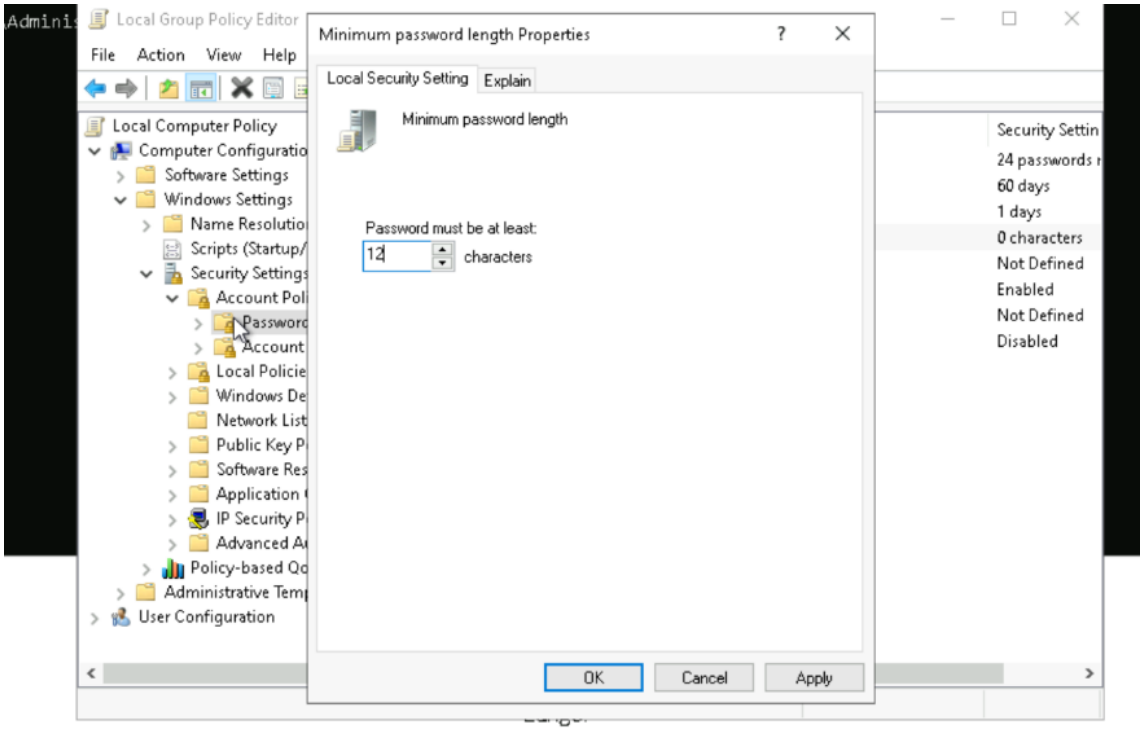
Paso 4: Configurar "Vigencia máxima de la contraseña" Configuré la vigencia en 60 días, para que la contraseña expire y deba cambiarse periódicamente.



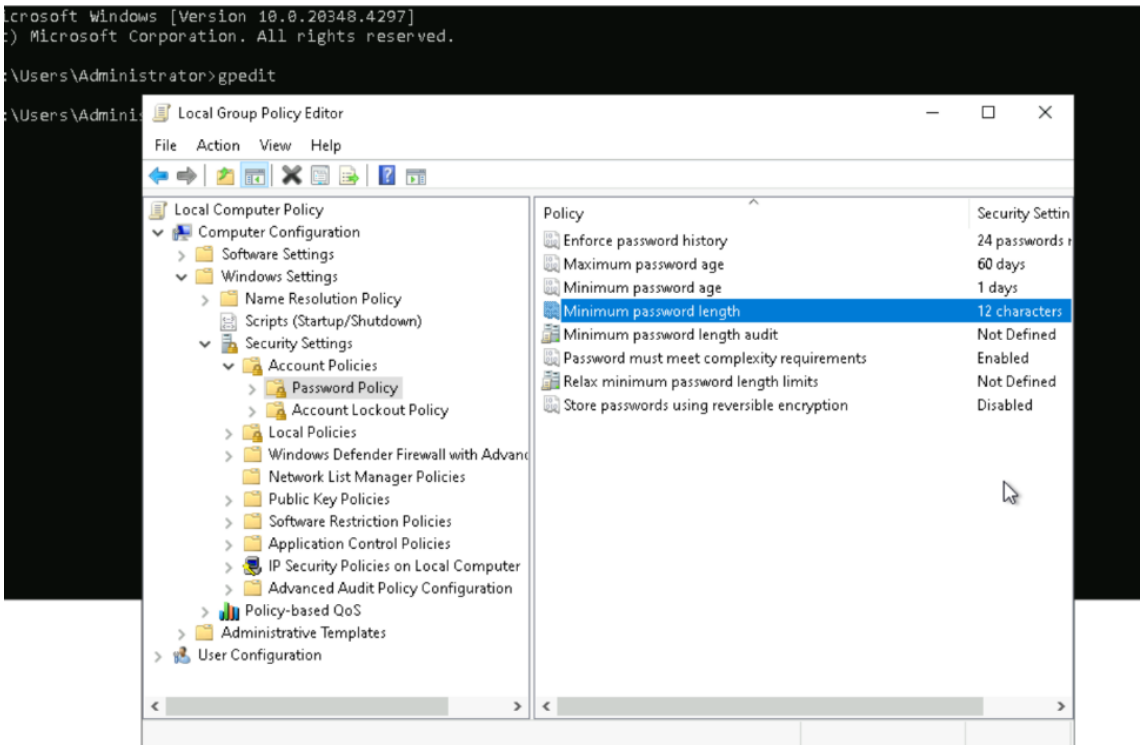
Paso 5: Configurar "Vigencia mínima de la contraseña" Configuré la vigencia mínima en 1 día, para que no se pueda cambiar la contraseña dos veces el mismo día.



Paso 6: Configurar "Longitud mínima de la contraseña" Configuré la longitud mínima en 12 caracteres, para obligar contraseñas largas.



Paso 7: Verificar los cambios Revisé el panel de configuración de seguridad y confirmé que todas las políticas quedaron aplicadas.



Resultados

- Las políticas quedaron configuradas según las recomendaciones de Microsoft.

- Un usuario que intente usar una contraseña débil será rechazado por el sistema.

Aprendizajes

- Las políticas de contraseña se aplican al inicio de sesión de Windows, no a servicios web como Gmail.
- Son un control preventivo (hardening): el administrador configura las reglas para que los usuarios no elijan contraseñas débiles.
- En un SOC, el analista verifica que estas políticas estén activas en los equipos.

Objective

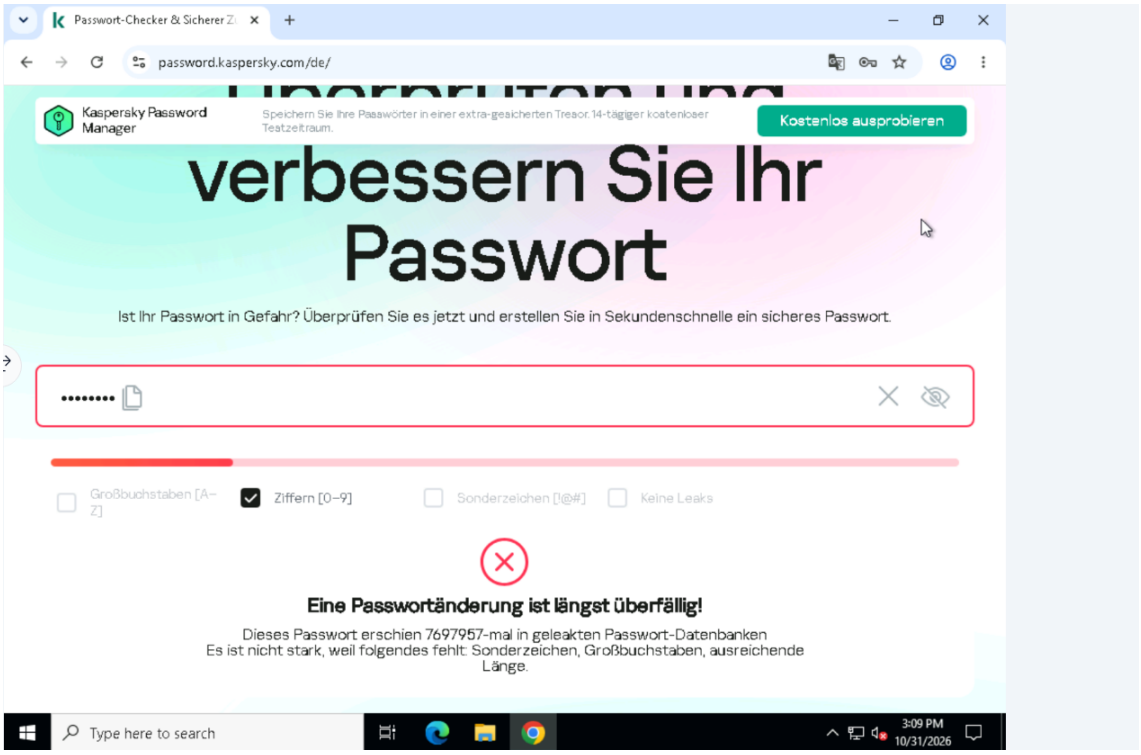
Learn to configure and verify strong password policies in Windows using the Local Group Policy Editor, and understand why they are a key preventive control in operating system security.

Tools and environment

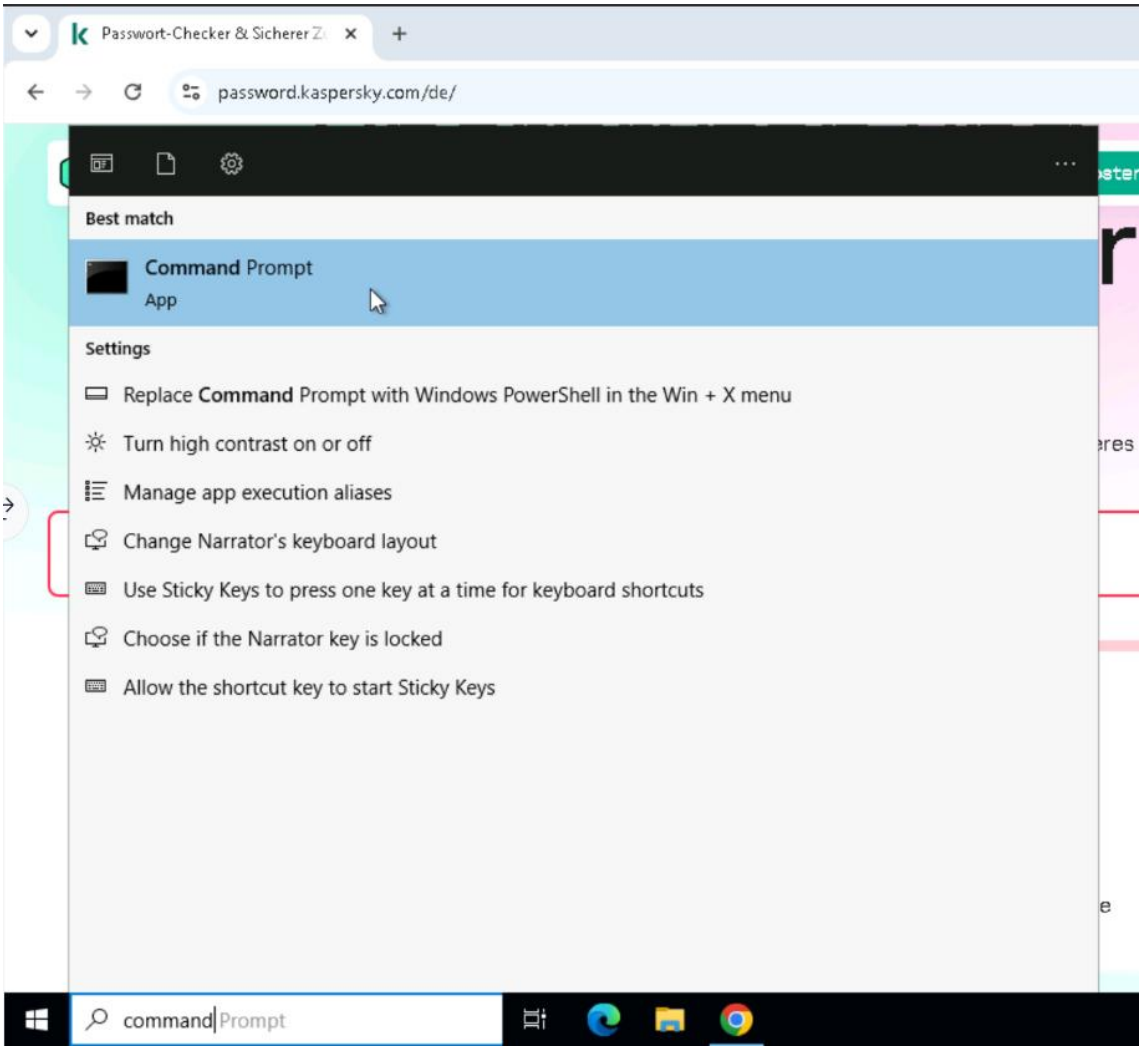
- OS: Windows (local machine / lab)
- Local Group Policy Editor (gpedit)
- Kaspersky Password Checker (to evaluate password strength)

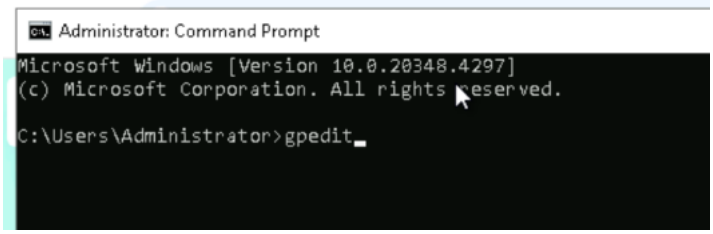
Steps performed

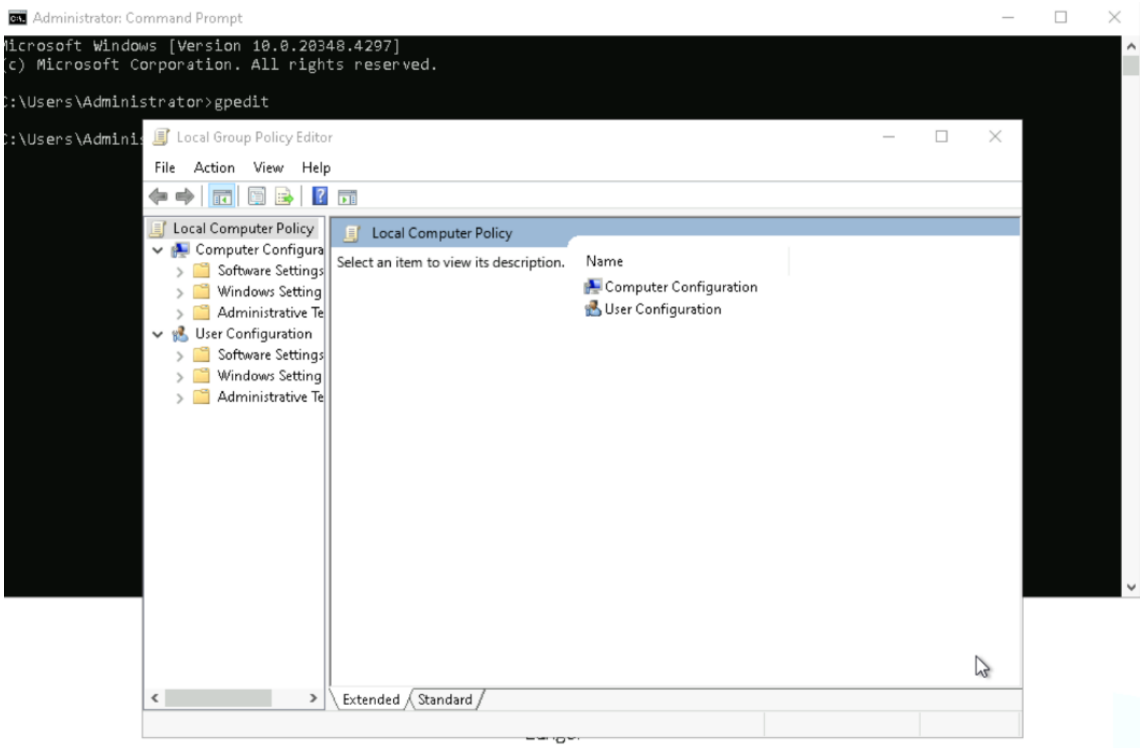
Step 1: Evaluate password strength with Kaspersky I opened Kaspersky Password Checker and tested passwords of different lengths and character variety, seeing how they affect cracking time.

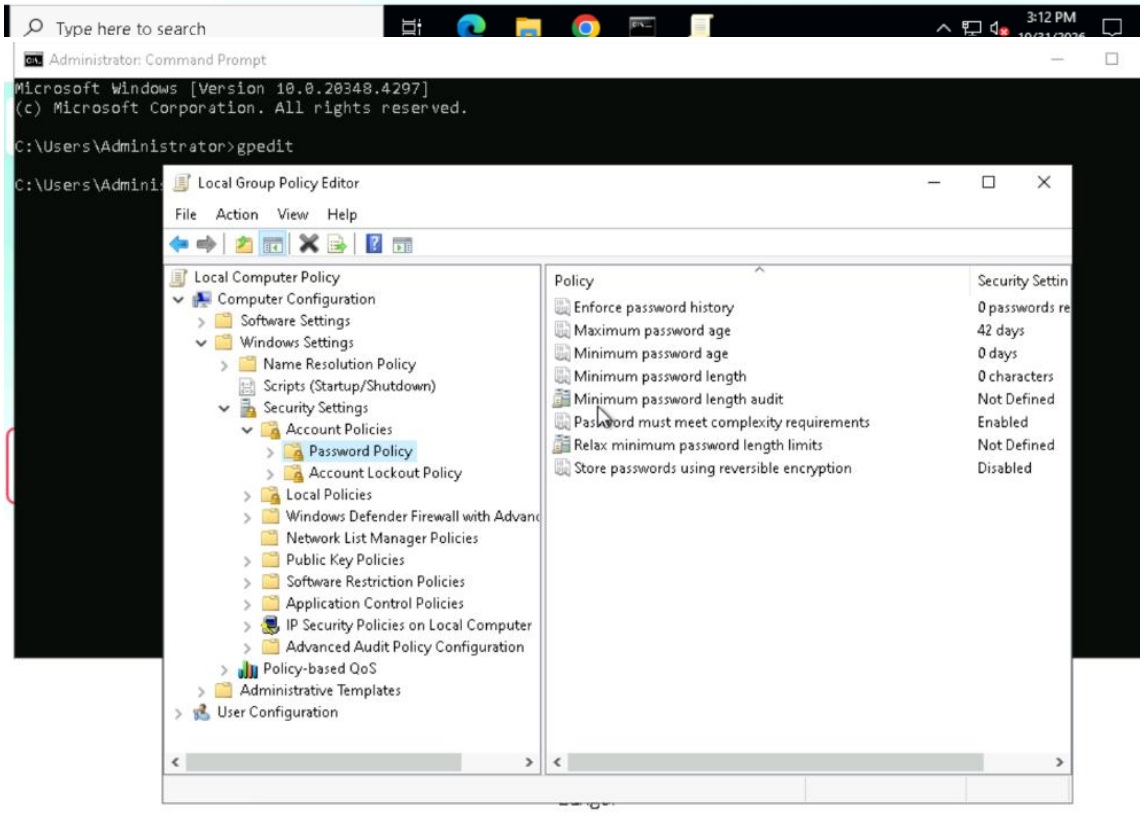


Step 2: Open the Local Group Policy Editor I opened the command prompt and ran `gpedit` to open the Local Group Policy Editor.

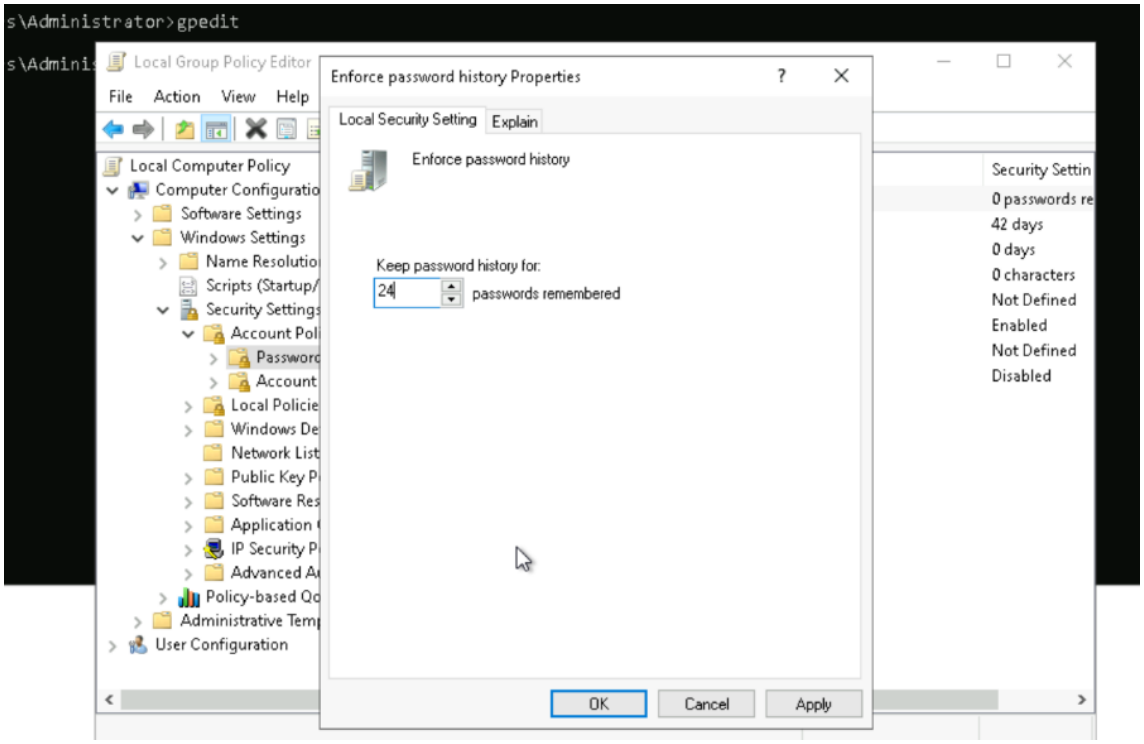

Passwort-Checker & Sicherer Z
password.kaspersky.com/de/
Best match
Command Prompt
App
Settings
Replace Command Prompt with Windows PowerShell in the Win + X menu
Turn high contrast on or off
Manage app execution aliases
Change Narrator's keyboard layout
Use Sticky Keys to press one key at a time for keyboard shortcuts
Choose if the Narrator key is locked
Allow the shortcut key to start Sticky Keys
command Prompt


Administrator: Command Prompt
Microsoft Windows [Version 10.0.20348.4297]
(c) Microsoft Corporation. All rights reserved.
C:\Users\Administrator>gpedit

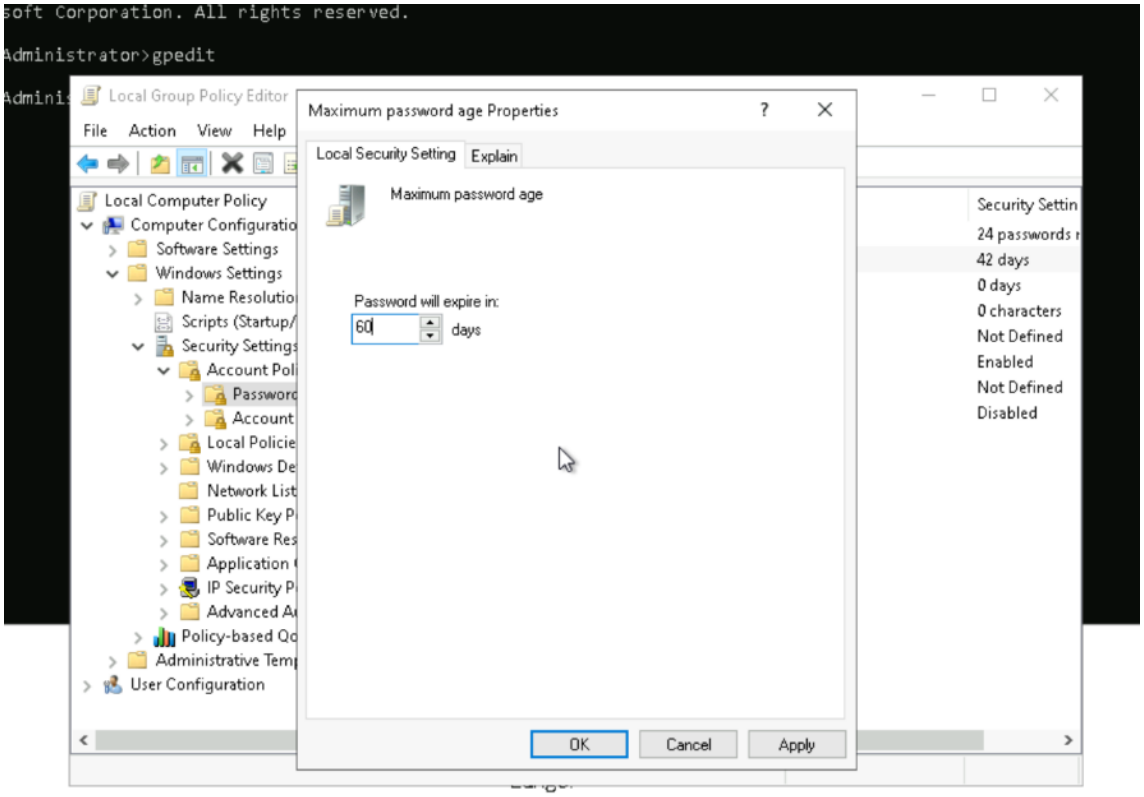




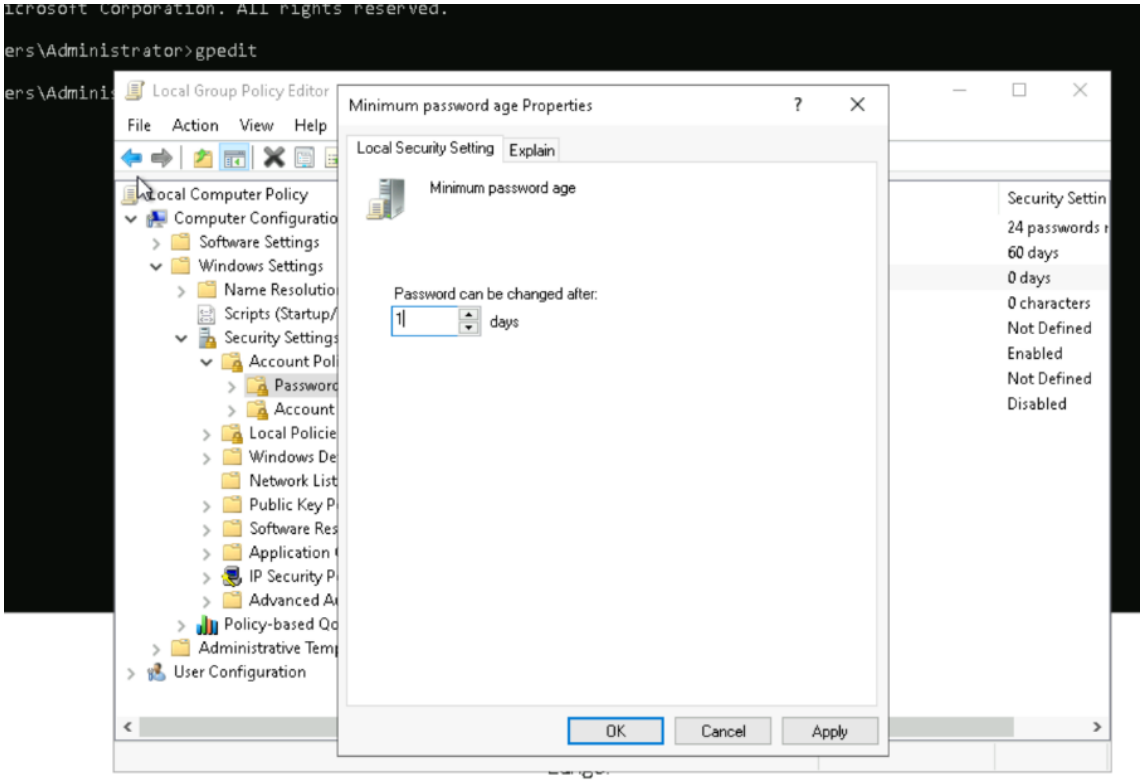
Step 3: Configure "Enforce password history" I set the history to 24, so the user cannot reuse the last 24 passwords.



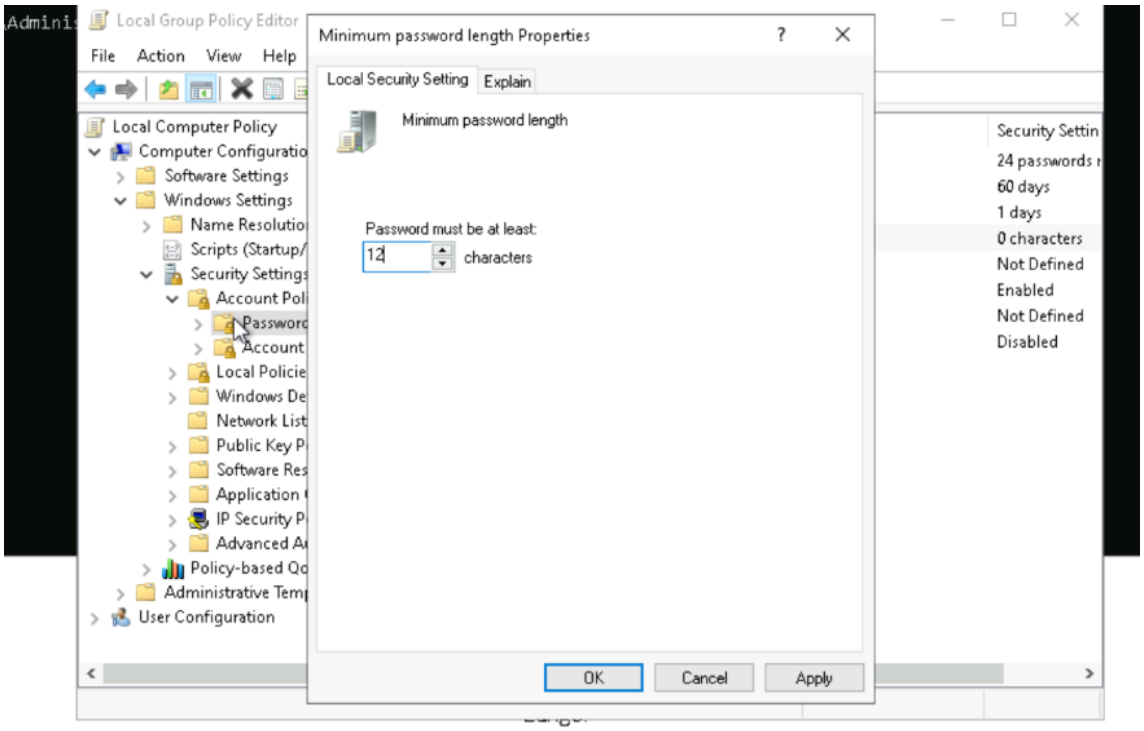
Step 4: Configure "Maximum password age" I set the age to 60 days, so the password expires and must be changed periodically.



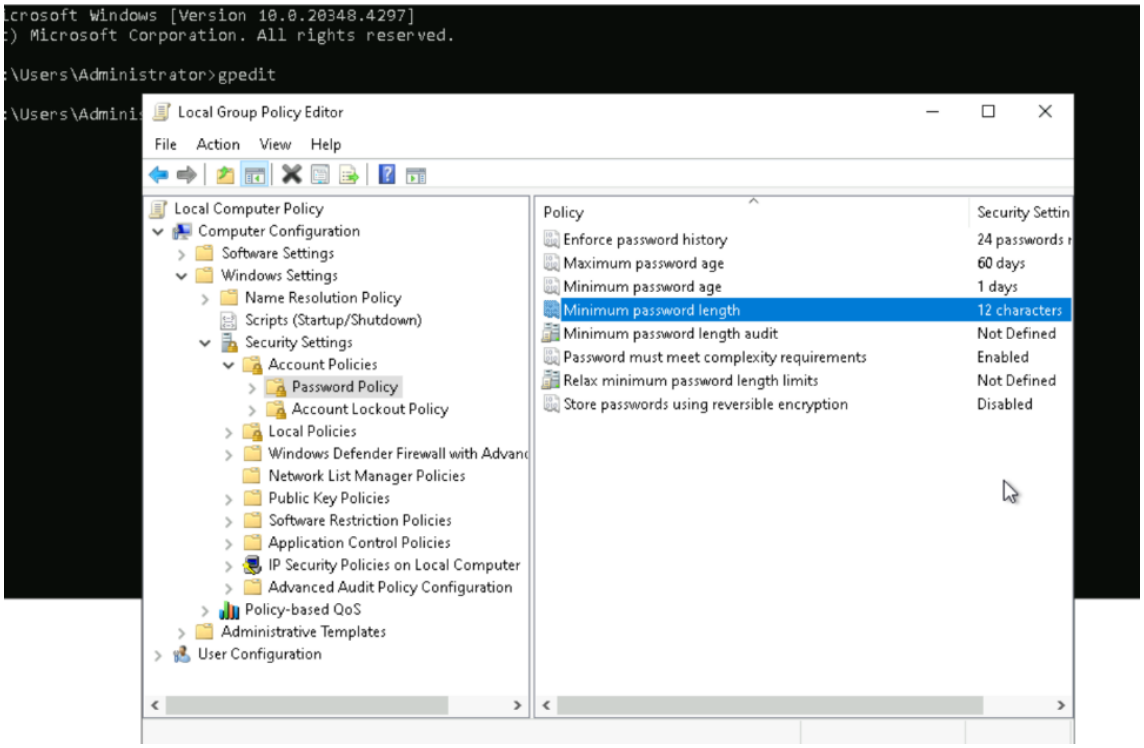
Step 5: Configure "Minimum password age" I set the minimum age to 1 day, so the password cannot be changed twice in the same day.



Step 6: Configure "Minimum password length" I set the minimum length to 12 characters, to enforce long passwords.



Step 7: Verify the changes I reviewed the security settings panel and confirmed that all policies were applied.



Results

- Policies were configured according to Microsoft recommendations.
- A user trying to use a weak password will be rejected by the system.

Lessons learned

- Password policies apply to Windows login, not to web services like Gmail.
- They are a preventive control (hardening): the administrator sets the rules so users cannot choose weak passwords.
- In a SOC, the analyst verifies that these policies are active on the machines.